

Security+ 1.2 · Non-repudiation

Mestre CyberSec · Aula 1.2 — Non-repudiation (7:57) · [Assistir Vídeo no YouTube](#) · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Não-repúdio: prova irrefutável de QUEM fez — impossível negar depois. Implementação: hash do dado cifrado com a chave PRIVADA de quem assina (assinatura digital). Qualquer um valida com a pública. Base de contrato digital, transação, log de auditoria.

💡 Highlights que a prova CompTIA cobra

- Hash só prova integridade; assinatura prova integridade + AUTOR
- Assimétrico: privada assina, pública valida
- Prova de não-Repúdio: 'não foi eu' é impossível de alegar após assinado

🎯 Dicas de Prova & Cenários Típicos da Banca

- Se a questão cita 'cannot deny'/'cannot dispute' = non-repudiation
- Qual algoritmo: RSA assinatura (não AES — AES é simétrico, sem autor único)

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Não-repúdio (N/A)

Objetivo de segurança que garante que uma parte não possa negar ter realizado uma ação, como assinar uma mensagem ou aprovar uma transação. Fornece prova irrefutável de origem ou autoria.

⚠ **Armadilha CompTIA:** Gatilho: 'cannot deny', 'cannot dispute', 'prova de autoria'. Não confunda com integridade: hash sozinho não dá não-repúdio.

• Assinatura Digital (N/A)

Técnica criptográfica que gera um hash dos dados e cifra/assina o hash com a chave privada do remetente. Prova integridade mais origem/autenticação e fornece não-repúdio.

⚠ **Armadilha CompTIA:** Assinatura digital = integridade + autor. Se a questão pedir 'não-repúdio', a resposta normalmente é assinatura digital, não apenas hash.

• Hash (Função de Hash) (N/A)

Função unidirecional que produz um resumo de tamanho fixo a partir de dados; verifica integridade ao detectar alterações. Sozinho, não prova quem criou ou enviou os dados.

⚠ **Armadilha CompTIA:** Hash = integridade apenas. Se a questão exige autor/não-repúdio, precisa de assinatura digital, não só hash.

• Criptografia Assimétrica (N/A)

Criptografia que usa um par de chaves: uma pública e uma privada. Para não-repúdio, o assinante usa a chave privada e os verificadores usam a chave pública correspondente.

⚠ **Armadilha CompTIA:** Assimétrico: privada assina, pública valida. Não use AES para assinatura/não-repúdio; AES é simétrico e não identifica autor único.

• Chave Privada (N/A)

A chave secreta em um par assimétrico, conhecida apenas pelo proprietário. Cria assinaturas digitais e decifra dados cifrados com a chave pública correspondente.

⚠ **Armadilha CompTIA:** Privada do signatário assina; nunca é compartilhada. Se a privada não for exclusiva, a alegação 'não foi eu' pode ser possível.

• Chave Pública (N/A)

A chave distribuível livremente em um par assimétrico. Verifica assinaturas digitais e cifra dados para o detentor da chave privada correspondente.

⚠ **Armadilha CompTIA:** Pública valida assinatura; não dá não-repúdio se usada para assinar, pois não é exclusiva do autor. Confirme sempre privada assina / pública valida.

• RSA

Algoritmo criptográfico assimétrico comumente usado para assinaturas digitais e troca de chaves. Em questões de não-repúdio do Security+, assinaturas RSA provam autoria via assinatura com chave privada e verificação com pública.

⚠ **Armadilha CompTIA:** Se pedir algoritmo para assinatura/não-repúdio, pense RSA/ECDSA/DSA (assimétricos). AES é simétrico e não prova autor único.

• Integridade (N/A)

Objetivo de segurança que garante que os dados não foram alterados ou adulterados. Hash prova integridade, mas não-repúdio exige também prova do autor.

⚠ **Armadilha CompTIA:** Integridade não é não-repúdio. Se a pergunta diz 'cannot deny', não basta hash/checksum; precisa de assinatura digital.

✓ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Um banco está projetando um sistema para clientes corporativos autorizarem transferências bancárias de alto valor online. O banco quer garantir que, após uma transferência ser enviada, o cliente não possa negar posteriormente tê-la autorizado. Qual controle o banco deve exigir para cada solicitação de transferência?

- A) Uma assinatura digital RSA gerada com a chave privada do cliente e verificada com a chave pública do cliente
- B) Criptografia da solicitação de transferência com a chave pública do banco
- C) Um hash SHA-256 da solicitação de transferência armazenado no banco de dados do banco
- D) Um segredo HMAC compartilhado gerado conjuntamente pelo banco e pelo cliente

QUESTÃO 2 · CENÁRIO DE EXAME

Uma plataforma de gestão de contratos recebe um acordo assinado eletronicamente. O destinatário precisa provar que a assinatura foi criada pelo remetente e que o remetente não pode negar tê-la assinado. Qual chave o destinatário deve usar para validar a assinatura?

- A) Chave privada do destinatário
- B) Chave pública do remetente
- C) Chave privada do remetente
- D) Chave privada da autoridade certificadora

QUESTÃO 3 · CENÁRIO DE EXAME

Dois departamentos compartilham uma chave HMAC simétrica para proteger entradas de log de auditoria. Durante uma disputa, um departamento afirma que o outro poderia ter modificado os logs porque ambos conhecem a mesma chave. Por que esse projeto de HMAC falha em fornecer não-repúdio?

- A) HMAC não usa uma função hash
- B) Qualquer departamento com a chave compartilhada poderia gerar um HMAC válido
- C) HMAC criptografa os logs com uma chave privada
- D) HMAC fornece confidencialidade, mas não integridade

QUESTÃO 4 · CENÁRIO DE EXAME

Uma empresa de software distribui patches de segurança pela Internet. Os clientes precisam verificar que um patch realmente veio da empresa e que a empresa não pode negar posteriormente tê-lo publicado. O que a empresa deve fazer?

- A) Assinar o hash do patch com a chave privada da empresa
- B) Criptografar o patch com a chave pública de cada cliente
- C) Publicar o hash do patch em um site HTTP
- D) Comprimir o patch com uma senha compartilhada pelos clientes

QUESTÃO 5 · CENÁRIO DE EXAME

Um administrador altera uma regra de firewall e depois nega ter feito a alteração. O sistema de gestão de mudanças da organização registra cada alteração e exige que administradores usem credenciais criptográficas pessoais. Qual evidência melhor permitiria aos investigadores provar qual administrador autorizou a alteração?

- A) Uma assinatura digital válida no registro de alteração verificada com a chave pública daquele administrador
- B) Uma chave de sessão simétrica usada durante o login SSH do administrador
- C) Um log de firewall mostrando o endereço IP de origem da estação de trabalho do administrador
- D) Um hash de senha armazenado no serviço de diretório para o administrador

QUESTÃO 6 · CENÁRIO DE EXAME

Uma prestadora de saúde envia um relatório de auditoria a um regulador. O regulador exige garantia de que o relatório foi criado pelo diretor de conformidade da prestadora e que o diretor não pode alegar posteriormente que foi forjado. Qual operação criptográfica o diretor de conformidade deve realizar?

- A) Criptografar o relatório com a chave pública do regulador
- B) Gerar o hash do relatório e criptografar o hash com a chave privada do diretor de conformidade
- C) Gerar o hash do relatório e armazenar o hash em um banco de dados local
- D) Criptografar o relatório com uma chave simétrica compartilhada com o regulador

QUESTÃO 7 · CENÁRIO DE EXAME

Uma empresa quer implementar assinaturas digitais para seus executivos, de modo que documentos de políticas assinados possam ser verificados por qualquer funcionário. Qual afirmação descreve o uso correto das chaves?

- A) Executivos assinam com suas chaves públicas; funcionários verificam com chaves privadas
- B) Executivos assinam com suas chaves privadas; funcionários verificam com as chaves públicas correspondentes
- C) Executivos assinam com uma chave simétrica compartilhada; funcionários verificam com a mesma chave
- D) Executivos assinam com a chave privada da CA; funcionários verificam com a chave pública da CA

QUESTÃO 8 · CENÁRIO DE EXAME

Um desenvolvedor envia código-fonte para um repositório. A gerência quer garantir que o desenvolvedor não possa negar posteriormente a autoria de um commit específico. Qual mecanismo deve ser habilitado?

- A) Assinar cada commit com a chave privada do desenvolvedor
- B) Criptografar cada commit com a chave pública do servidor de repositório
- C) Exigir que o desenvolvedor use uma senha de equipe compartilhada para commits
- D) Armazenar apenas o hash MD5 de cada commit no repositório

QUESTÃO 9 · CENÁRIO DE EXAME

Um fornecedor e um comprador finalizam um acordo de compra eletronicamente. Ambas as partes querem impedir que a outra negue posteriormente a concordância com os termos. Qual implementação melhor atende a esse requisito?

- A) Ambas as partes assinam digitalmente o hash do acordo com suas próprias chaves privadas
- B) Ambas as partes criptografam o acordo com uma chave AES compartilhada
- C) O comprador gera o hash do acordo e envia o hash ao fornecedor
- D) O fornecedor armazena o acordo em um servidor de arquivos somente leitura

QUESTÃO 10 · CENÁRIO DE EXAME

Um arquiteto de segurança implementa um controle em que cada corretor assina ordens de negociação com uma chave privada pessoal, e a plataforma as verifica com a chave pública do corretor. Qual propriedade de segurança esse controle fornece principalmente?

- A)** Não-repúdio
- B)** Confidencialidade
- C)** Disponibilidade
- D)** Ofuscação

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa A — Uma assinatura digital RSA gerada com a chave privada do cliente e verificada com a chave pública do cliente

Correto: a assinatura digital com a chave privada do signatário fornece não-repúdio, pois somente o cliente possui a chave privada. Criptografar com a chave pública do banco fornece confidencialidade; hash sozinho fornece integridade, mas não origem/não-repúdio; HMAC compartilhado pode ser gerado por qualquer uma das partes, então é repudiável.

Questão 2: Alternativa B — Chave pública do remetente

Correto: assinaturas digitais são verificadas com a chave pública do signatário. A chave privada do remetente é secreta; a chave privada do destinatário é para descryptografia ou assinatura pelo destinatário; a chave privada da CA assina certificados, não o contrato.

Questão 3: Alternativa B — Qualquer departamento com a chave compartilhada poderia gerar um HMAC válido

Correto: com um segredo compartilhado, ambas as partes podem criar o MAC, então não se pode provar qual parte gerou. HMAC usa hash; não usa chave privada para criptografar; ele fornece integridade e autenticação simétrica, mas não não-repúdio.

Questão 4: Alternativa A — Assinar o hash do patch com a chave privada da empresa

Correto: assinatura de código ou assinatura digital com a chave privada da empresa fornece não-repúdio e permite verificação com a chave pública. Criptografia por cliente não prova origem; hash em HTTP pode ser alterado; senha compartilhada não prova origem.

Questão 5: Alternativa A — Uma assinatura digital válida no registro de alteração verificada com a chave pública daquele administrador

Correto: a assinatura digital vincula a identidade ao registro e fornece não-repúdio. Chave de sessão SSH é compartilhada ou efêmera; IP pode ser falsificado ou compartilhado; hash de senha autentica login, mas não assina o registro e pode ser usado por outro se comprometido.

Questão 6: Alternativa B — Gerar o hash do relatório e criptografar o hash com a chave privada do diretor de conformidade

Correto: assinar o hash com a chave privada é uma assinatura digital e fornece não-repúdio. Criptografia com chave pública do regulador dá confidencialidade; hash local não prova autoria; chave simétrica compartilhada é repudiável.

Questão 7: Alternativa B — Executivos assinam com suas chaves privadas; funcionários verificam com as chaves públicas correspondentes

Correto: a chave privada assina e a chave pública verifica. O inverso é inválido e inseguro; chave simétrica não fornece não-repúdio; a chave da CA assina certificados, não documentos, a menos que a própria CA seja a signatária.

Questão 8: Alternativa A — Assinar cada commit com a chave privada do desenvolvedor

Correto: assinatura de commit usa a chave privada do desenvolvedor e verifica com a chave pública; fornece não-repúdio. Criptografia para o servidor não prova autoria; senha compartilhada não é única; hash sozinho não identifica autor.

Questão 9: Alternativa A — Ambas as partes assinam digitalmente o hash do acordo com suas próprias chaves privadas

Correto: cada assinatura com chave privada fornece não-repúdio para cada parte. Chave AES compartilhada é repudiável; hash sozinho não assina; servidor somente leitura não prova concordância de ambas.

Questão 10: Alternativa A — Não-repúdio

Correto: não-repúdio impede negar a origem ou a ação. Confidencialidade protege contra divulgação; disponibilidade garante acesso; ofuscação oculta código. A assinatura digital com chave privada é o mecanismo usado aqui.